

SÉCURITÉ DES E-MAILS

PGP, S/MIME

Sécurité des e-mails

- ▶ La messagerie électronique est l'une des applications réseau les plus utilisées
- ▶ Si le contenu des messages n'est pas sécurisé normalement
 - ▶ celui-ci peut être lu / modifié en transit ou à destination par l'attaquant
- ▶ Le service de courrier électronique est comme le service de carte postale
 - ▶ il suffit de le choisir et de le lire

Améliorations de la sécurité des e-mails

- ▶ confidentialité
 - ▶ protection contre la divulgation
- ▶ authentification
 - ▶ de l'expéditeur du message
- ▶ intégrité du message
 - ▶ protection contre la modification
- ▶ non-répudiation d'origine
 - ▶ protection contre le refus de l'expéditeur

Pretty Good Privacy (PGP)

- ▶ logiciel de messagerie électronique sécurisé largement utilisé
 - ▶ à l'origine une fonction de cryptage / décryptage de fichiers
- ▶ développé par Phil Zimmermann
- ▶ les meilleurs algorithmes cryptographiques disponibles sont utilisés
- ▶ disponible sur plusieurs plateformes avec code source
- ▶ à l'origine gratuit, il existe maintenant des versions commerciales
- ▶ non contrôlé par un organisme de normalisation
 - ▶ malgré l'existence de RFC

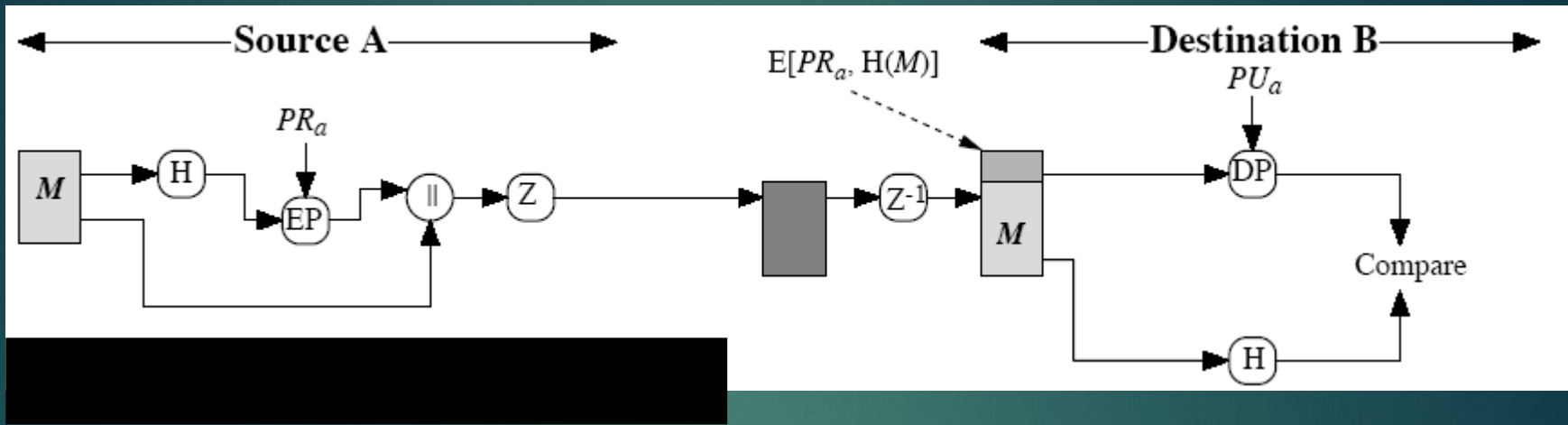
Mécanismes PGP

5

- ▶ **Signatures numériques** (et par conséquent authentification et intégrité des messages)
 - ▶ RSA, DSS et autres
- ▶ **Chiffrement des messages**
 - ▶ CAST, IDEA, 3DES, AES, etc. (tous au moins 128 bits)
 - ▶ les clés symétriques sont utilisées une fois et cryptées à l'aide de RSA ou ElGamal (basé sur le logarithme discret)
- ▶ **Compression** avec l'algorithme **ZIP**
- ▶ **Conversion Radix-64** (en ASCII)
 - ▶ pour la compatibilité des e-mails
- ▶ **Segmentation**
 - ▶ pour le contournement de la restriction liée à la limitation de taille de message

Fonctionnement de PGP - Signatures numériques

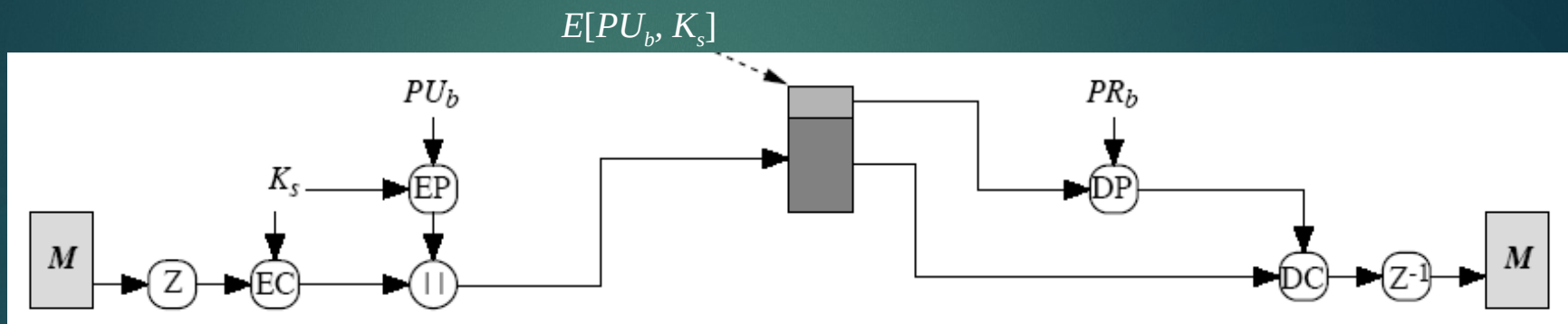
6



- ▶ Application classique de la crypto à clé publique
 - ▶ ce schéma est en fait pour **RSA**
 - ▶ possible avec **DSA**
- ▶ Z est la fonction **zip**
- ▶ la conversion **radix-64** est effectuée après zip chez l'expéditeur, avant Z^{-1} chez le récepteur
 - ▶ ne peut être fait que pour la signature ou pour l'ensemble du message

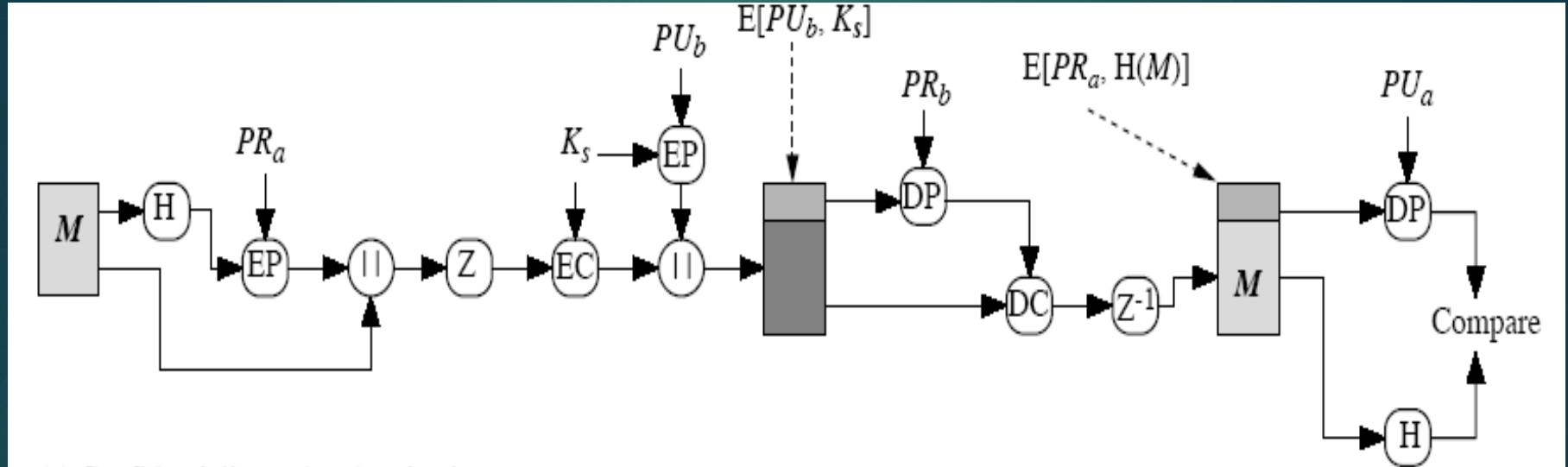
Fonctionnement de PGP - Confidentialité

7



- ▶ Clé de session à usage unique, K_s
 - ▶ générée aléatoirement
 - ▶ cryptée à l'aide d'un cryptosystème à clé publique, EP
 - ▶ RSA ou ElGamal
- ▶ Le message est **compressé avant le cryptage**
 - ▶ C'est le cas par défaut

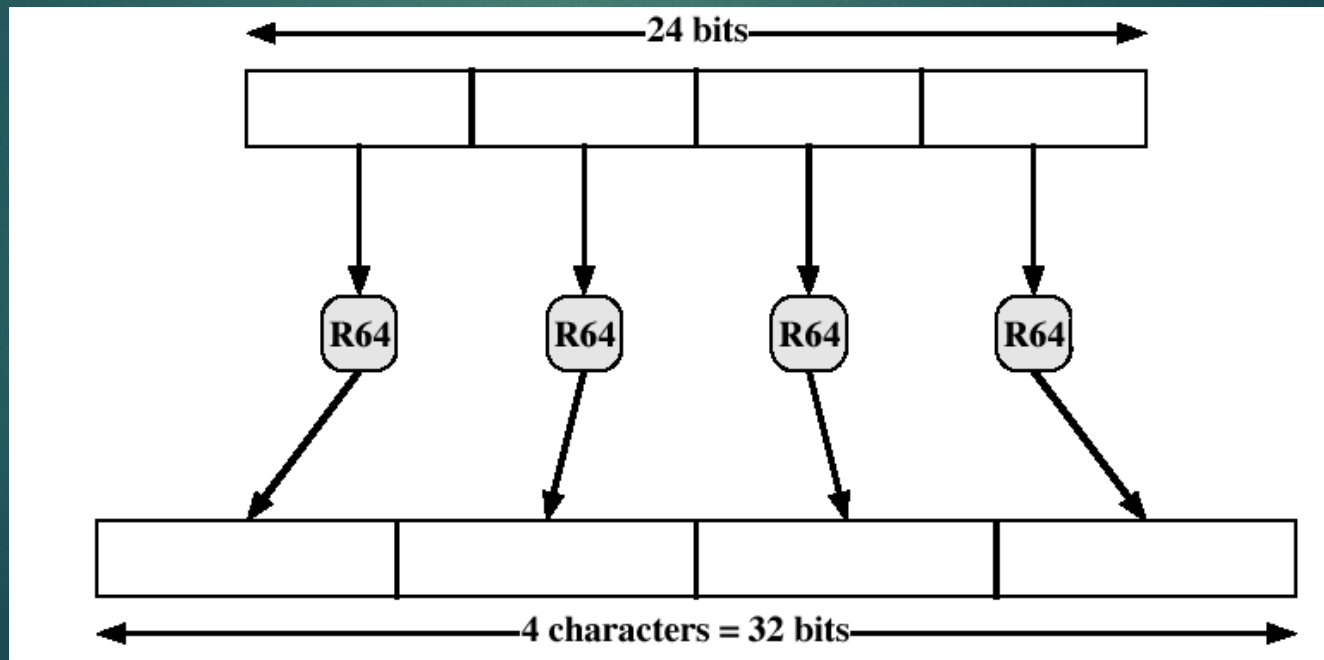
Fonctionnement de PGP - Confidentialité et Authentification



- ▶ utilise les deux services sur le même message
 - ▶ créer une signature et joindre au message
 - ▶ compresser et crypter le message et la signature
 - ▶ joindre une clé de session chiffrée
 - ▶ la conversion radix-64 est pour tout à la fin

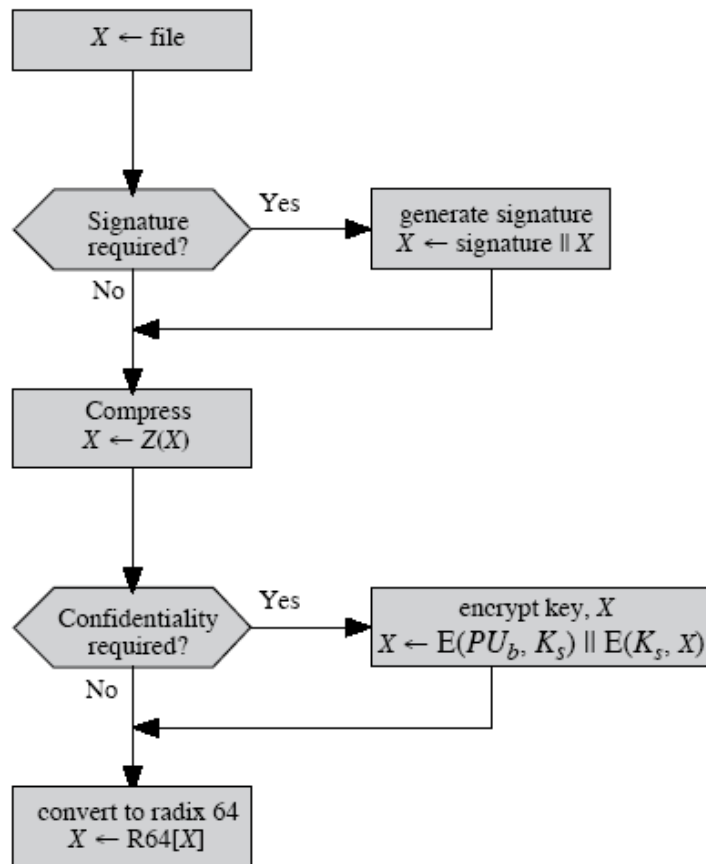
Fonctionnement de PGP - Conversion Radix-64

- ▶ Le texte et les signatures cryptés créent une sortie binaire
- ▶ Cependant, l'e-mail a été conçu uniquement pour le texte
 - ▶ par conséquent, PGP doit encoder les données binaires brutes en caractères ASCII imprimables
- ▶ utilise l'algorithme radix-64
 - ▶ mappe 3 octets à 4 caractères imprimables

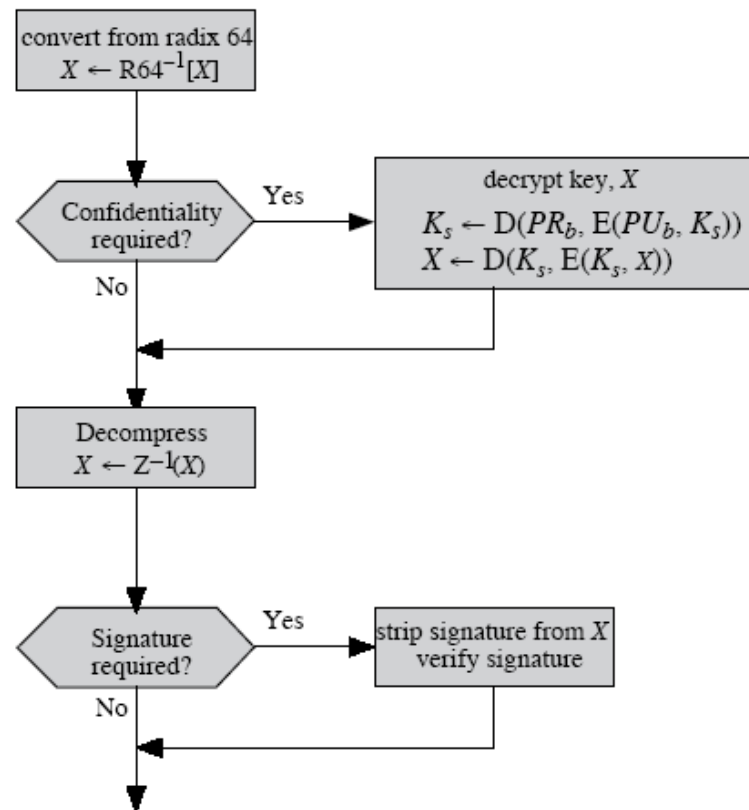


Fonctionnement de PGP - Résumé

10



(a) Generic Transmission Diagram (from A)



(b) Generic Reception Diagram (to B)

S/MIME

11

- ▶ Secure/Multipurpose Internet Mail Extension
- ▶ Un moyen standard pour le cryptage et la signature des e-mails
- ▶ IETF effort (RFCs 2632, 2633 - pour la version 3.0; RFCs 3850, 3851 pour la version 3.1; 5750, 5751 pour la version 3.2)
- ▶ Soutien de l'industrie
- ▶ Pas un logiciel autonome, un système qui doit être pris en charge par les clients de messagerie
 - ▶ comme MS Outlook et Thunderbird
- ▶ S / MIME gère les signatures numériques
 - ▶ Fournit également le cryptage

Brève Historique des e-mails

12

- ▶ SMTP et RFC 822 (plus tard RFC 5322)
 - ▶ SMTP est le protocole de transfert de courrier électronique fonctionnant sur TCP
 - ▶ RFC 822/5322 définit le format du message et les en-têtes
 - ▶ uniquement les **messages ASCII** (7 bits)
- ▶ MIME (Multipurpose Internet Mail Extensions)
 - ▶ type de contenu
 - ▶ Presque tous les types d'informations peuvent apparaître dans un e-mail
 - ▶ codage de transfert
 - ▶ Spécifie comment le corps du message est **encodé sous forme textuelle** (radix64 est courant)
- ▶ S / MIME: MIME sécurisé
 - ▶ **nouveaux types de contenu**, comme la signature, les données chiffrées

S/MIME - Fonctions fournies

13

- ▶ **données enveloppées**
 - ▶ n'importe quel type de contenu chiffré et les clés qui ont servi à le chiffré
- ▶ **données signées**
 - ▶ Le contenu du message et sa signature sont encodés
 - ▶ Signature via la clé privée du signataire
- ▶ **données clairement signées**
 - ▶ Seule la signature du message en clair est encodé
 - ▶ Radix 64 pour l'encodage
- ▶ **données signées et enveloppées**
 - ▶ des données chiffrées peuvent être signées et vice versa
 - ▶ Entités signées et chiffrées imbriquées

S/MIME - Algorithmes Cryptographiques

14

- ▶ fonctions de hachage : basculé sur **SHA256**
- ▶ signatures numériques : **RSA** est principalement utilisé
- ▶ cryptage de la **clé de session** : **RSA** est principalement utilisé
- ▶ cryptage des messages : Triple-DES, AES et autres, mais AES-128 est préférable
- ▶ Le **codage Base64 (radix64)** est utilisé pour la compatibilité des e-mails (conversion ASCII)
- ▶ l'expéditeur doit **connaître les capacités de déchiffrement de l'entité réceptrice** (annonce publique ou messages précédemment reçus du destinataire)
 - ▶ **sinon** l'expéditeur **prend le risque** d'envoyer un **e-mail inintelligible**.